COMPTIA SECURITY+ SY0-701 | DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.8 · Incident Response

Mestre CyberSec · **Lesson 4.8 — Incident Response** (9:14) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** NIST: Preparation → Detection/Analysis → Containment → Eradication → Recovery → Lessons Learned. Containment FIRST (isola antes de limpar). Lessons Learned alimenta a próxima Preparation.

💡 Key Exam Highlights & Critical Concepts

- Preparação → Detecção → Contenção → Erradicação → Recuperação → Lições aprendidas
- CONTAINMENT primeiro: isola a propagação ANTES de limpar
- Lessons Learned alimenta novamente a Preparação

🎯 Exam Tips & Typical CompTIA Scenarios

- 'isolates affected systems to prevent spread'=Containment

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.8 — Incident Response)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Incident Response Plan (IRP)

A documented set of procedures, roles, and communication paths used to prepare for, detect, respond to, and recover from security incidents.

⚠ ***Exam Trap:*** *Preparation means creating the IRP before an incident; if the scenario says 'no plan' or 'roles undefined', the missing phase is Preparation.*

• Preparation (N/A)

The incident response phase where policies, plans, teams, tools, training, and communication channels are established before an incident occurs.

⚠ ***Exam Trap:*** *Exam trigger: 'before the incident' or 'readiness' = Preparation. It feeds all later phases and is improved by Lessons Learned.*

• Detection and Analysis (N/A)

The phase that identifies potential security incidents, validates alerts, determines scope and impact, and gathers evidence to confirm whether an incident occurred.

⚠ ***Exam Trap:*** *Distinguish from Containment: detecting or validating an incident is Detection and Analysis; isolating systems is Containment.*

• Containment (N/A)

The incident response phase that limits damage and prevents further spread of the incident, often by isolating affected systems or network segments.

⚠ ***Exam Trap:*** *Exam trigger: 'isolates affected systems to prevent spread' = Containment. CompTIA often tests that containment comes before eradication or cleaning.*

• Eradication (N/A)

The phase that removes the root cause, malware, attacker access, or vulnerable components from affected systems after containment.

⚠️ ***Exam Trap:*** *If the question says 'remove malware' or 'eliminate the root cause' after isolation, choose Eradication, not Containment or Recovery.*

• Recovery (N/A)

The phase that restores affected systems and services to normal operation, validates functionality, and monitors for signs of recurrence.

⚠️ ***Exam Trap:*** *Exam trigger: 'restore normal operations' or 'return to production' = Recovery. It follows Eradication, but containment must happen first.*

• Lessons Learned (N/A)

The post-incident review phase that documents what happened, identifies gaps, and updates preparation plans and procedures to improve future response.

⚠️ ***Exam Trap:*** *Exam trigger: 'after-action review' or 'improve future response' = Lessons Learned. It feeds back into Preparation.*

• Isolation (N/A)

A containment action that separates an affected system or network segment from other resources to stop lateral movement or data exfiltration.

⚠️ ***Exam Trap:*** *If the question asks the immediate first action after identifying active spread, choose isolation/containment before cleaning or rebooting.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hospital's security team confirms that a file server is actively encrypting shared documents with ransomware. The IRP is activated. Which action should the team take FIRST?

A) Disconnect the server from the network while preserving its power state.

B) Restore the server from last night's backup.

C) Run a full antivirus scan to remove the ransomware.

D) Reimage the server with a clean operating system.

QUESTION 2 · EXAM SCENARIO

An analyst finds a workstation communicating with a known command-and-control server. The user is still logged in, and volatile evidence may be needed for the investigation. Which containment action is MOST appropriate?

A) Power off the workstation immediately to stop malicious activity.

B) Disable the switch port or disconnect the network cable without shutting down the OS.

C) Delete the suspicious files and reboot the workstation.

D) Reformat the workstation and reinstall applications.

QUESTION 3 · EXAM SCENARIO

After recovery has been completed and normal operations restored following a phishing breach, the CISO asks why the incident was not detected sooner. Which activity should be performed NEXT according to the NIST IR lifecycle?

A) Immediate containment of affected mail servers.

B) Full eradication of remaining malware.

C) Lessons learned review with stakeholders to update detection rules and training.

D) Recovery point objective validation.

QUESTION 4 · EXAM SCENARIO

A company has no formal IR process. Management wants to improve readiness before the next major cyber event. Which action BEST supports the Preparation phase?

A) Purchase forensic tools but do not document procedures.

B) Wait for an alert before defining roles and escalation paths.

C) Isolate all production servers from the internet permanently.

D) Conduct tabletop exercises and update the incident response plan based on results.

QUESTION 5 · EXAM SCENARIO

A SIEM generates an alert for unusual outbound traffic from a finance workstation at 2 a.m. The analyst must decide whether the alert represents a real incident and determine its scope. Which NIST IR phase is being performed?

A) Preparation

B) Detection and Analysis

C) Containment

D) Lessons Learned

QUESTION 6 · EXAM SCENARIO

A malware infection has been contained on several endpoints. The team removes the malicious binaries, patches the exploited vulnerability, and resets compromised credentials. Which phase of the NIST IR lifecycle does this represent?

A) Recovery

B) Preparation

C) Detection and Analysis

D) Eradication

QUESTION 7 · EXAM SCENARIO

After malware is removed from an e-commerce server, the team restores the server from a verified clean backup, returns it to the load balancer, and monitors it closely for reinfection. Which phase is this?

A) Containment

B) Eradication

C) Recovery

D) Lessons Learned

QUESTION 8 · EXAM SCENARIO

A worm is spreading rapidly across a flat internal network. The IR team has identified infected hosts but cannot immediately remediate all of them. Which containment approach is MOST appropriate?

A) Delete the worm from one host and wait for antivirus definitions.

B) Power off the entire data center to stop all traffic.

C) Isolate affected network segments or VLANs to limit lateral spread.

D) Begin lessons learned while the worm continues to spread.

QUESTION 9 · EXAM SCENARIO

During an investigation of suspected intellectual property theft, legal counsel requires that forensic evidence be admissible in court. The endpoint has been isolated. What should the team do BEFORE reimaging the system?

A) Run disk cleanup to remove temporary files.

B) Reinstall the operating system to remove artifacts.

C) Delete user profiles and rotate passwords.

D) Create a forensic image and document chain of custody.

QUESTION 10 · EXAM SCENARIO

A customer database breach is confirmed. The incident response plan specifies notification requirements for legal, compliance, and executive teams. After initial containment, what should the incident commander do NEXT?

A) Post technical details on social media to warn customers.

B) Follow the IRP communication and escalation procedures to notify required stakeholders.

C) Wait until eradication is complete before informing legal counsel.

D) Ask affected customers to investigate the breach themselves.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Disconnect the server from the network while preserving its power state.
NIST IR requires containment before eradication or recovery. Isolating the server limits spread and preserves volatile evidence. Restoring, scanning to clean, or reimaging before containment can allow the attack to continue and may destroy evidence.

Question 2: Option B — Disable the switch port or disconnect the network cable without shutting down the OS.
Containment should isolate the host from the network while preserving volatile evidence such as RAM. Powering off destroys memory-resident evidence. Deleting files or reformatting is eradication/recovery and should occur after containment and analysis.

Question 3: Option C — Lessons learned review with stakeholders to update detection rules and training.
Lessons learned follows recovery and reviews what happened, why detection was delayed, and what improvements are needed. Its outputs feed back into Preparation by updating the IRP, monitoring rules, and training. Containment and eradication should already be complete.

Question 4: Option D — Conduct tabletop exercises and update the incident response plan based on results.
Preparation includes creating and maintaining the IRP, defining roles, establishing communications, training staff, and testing through exercises. Tabletop exercises reveal gaps that can be fixed before an incident. Tools without procedures or undefined roles do not provide readiness.

Question 5: Option B — Detection and Analysis
Detection and Analysis involves monitoring, triaging alerts, validating whether an event is a true incident, and determining scope and impact. Containment begins after the incident is confirmed and understood sufficiently to act.

Question 6: Option D — Eradication
Eradication removes the cause of the incident, such as malware, vulnerabilities, and compromised credentials, after containment. Recovery then restores normal operations and monitors for recurrence.

Question 7: Option C — Recovery
Recovery involves restoring systems and services to normal operation from trusted backups and validating that they are safe, while monitoring for signs of reinfection. Eradication already occurred when the malware was removed.

Question 8: Option C — Isolate affected network segments or VLANs to limit lateral spread.
Containment should limit the spread while allowing critical business functions to continue where possible. Segmenting or isolating affected VLANs slows lateral movement. Deleting from one host is insufficient, powering off the entire data center is excessively disruptive, and lessons learned occurs later.

Question 9: Option D — Create a forensic image and document chain of custody.
Before eradication or recovery destroys evidence, the team must preserve it through a forensic image and maintain chain of custody. Cleaning, reinstalling, or deleting artifacts would alter the evidence and harm admissibility.

Question 10: Option B — Follow the IRP communication and escalation procedures to notify required stakeholders.
The IRP should define communication and escalation paths, including legal, compliance, and executive notification. Delaying legal notification can violate regulatory deadlines, while public disclosure without coordination may increase harm and legal risk.